PROGETTO DI FINE MODULO / W24D4

Active Directory, SIEM & Detection

Laboratorio di cybersecurity con Windows Server, client Windows, Kali Linux e Splunk

Relazione tecnica finale | 11–12 ottobre 2026

Dominio: cyberlab.test • Virtualizzazione UTM • Rete 192.168.64.0/24

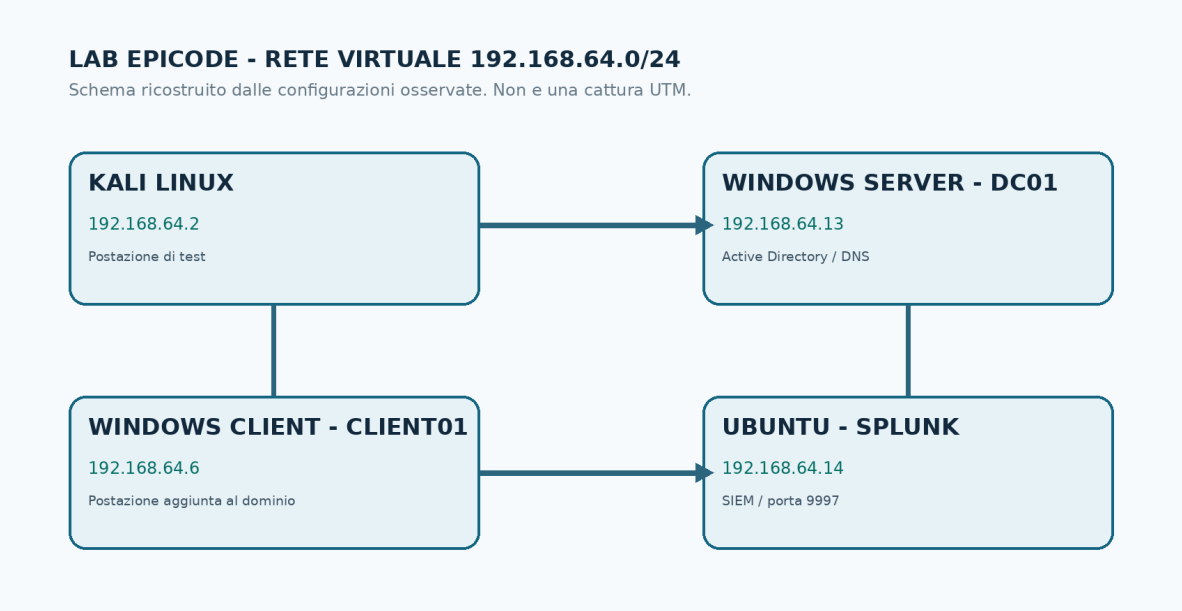


Figura 1 — Schema logico del laboratorio ricostruito dagli indirizzi e dai ruoli configurati.

Obiettivo del progetto

Realizzare un dominio Active Directory utilizzabile da una workstation Windows, centralizzare i registri di sicurezza in Splunk Enterprise e verificare il comportamento delle difese attraverso tre famiglie di test controllati: ricognizione, autenticazione e accesso remoto.

Ambito: ambiente didattico isolato. Le evidenze illustrate derivano dalle acquisizioni del laboratorio; diagrammi, query e tabelle di analisi sono elaborazioni tecniche originali.

01 / LABORATORIO PRATICO

Executive summary

Architettura realizzata, capacità di monitoraggio e risultati misurabili

L'infrastruttura comprende quattro macchine virtuali sulla medesima rete UTM. Il Domain Controller DC01 gestisce il dominio cyberlab.test, l'autenticazione e i servizi DNS; client01 rappresenta la postazione Windows associata al dominio; Splunk raccoglie i Windows Event Log di entrambi gli host; Kali genera attività di verifica autorizzate.

Componente	Host/IP	Ruolo
Domain Controller	DC01 · 192.168.64.13	AD DS, DNS, Kerberos, SMB, WinRM
Endpoint Windows	client01 · 192.168.64.6	Client di dominio e sorgente Event Log
SIEM	splunk01 · 192.168.64.14	Splunk Enterprise; receiver TCP 9997
Test station	Kali · 192.168.64.2	Ricognizione e simulazioni controllate

Risultati principali

Area	Evidenza osservata	Valutazione
Visibilità Windows	37.217 eventi Security client01; 3.068 DC01	Raccolta attiva per entrambi gli host
Ricognizione	Nmap rileva DNS, Kerberos, SMB, LDAP e WinRM	Superficie esposta identificata
Accessi anonimi	LDAP/RPC negano interrogazioni senza credenziali	Limitazione osservata
Credenziali	Security 4625: account test_epicode, origine Kali	Rilevamento SIEM confermato
Kerberos	GetNPUsers: preautenticazione richiesta	Nessun dato AS-REP utilizzabile
Accesso remoto	Evil-WinRM + whoami = cyberlab\administrator	Esecuzione remota riuscita

Il risultato centrale è la correlazione verificabile fra un tentativo SMB fallito da Kali e l'evento di sicurezza registrato da Windows e acquisito da Splunk. La visibilità del client è dimostrata separatamente dal conteggio degli eventi raccolti. Le altre prove consentono di osservare i servizi e i controlli di autenticazione, senza attribuire al SIEM eventi non identificati con certezza.

02 / LABORATORIO PRATICO

Preparazione dell'ambiente virtuale e messa in esercizio dei servizi

La fase preparatoria ha previsto la costruzione progressiva dell'infrastruttura in UTM: configurazione della rete virtuale, predisposizione del Domain Controller, gestione del dominio e delle identità, ingresso del client Windows e attivazione della raccolta centralizzata dei log. Le figure seguenti sono estratte dagli screenshot prodotti durante le installazioni: documentano le principali tappe e costituiscono la base operativa delle successive simulazioni di sicurezza.

1.1 Piattaforma UTM e connettività tra le macchine virtuali

L'ambiente è stato realizzato su un Mac con processore Apple Silicon e 8 GB di RAM, usando UTM per ospitare Windows Server (DC01), Windows 10 (client01), Ubuntu con Splunk Enterprise (splunk01) e Kali Linux. Le macchine sono state collegate a una rete virtuale condivisa per rendere raggiungibili i servizi del dominio e il collettore degli eventi. Gli indirizzi rilevati nella sessione di test erano DC01 192.168.64.13, client01 192.168.64.6, splunk01 192.168.64.14 e Kali 192.168.64.2; la configurazione UTM può comportare assegnazioni diverse in un avvio successivo.

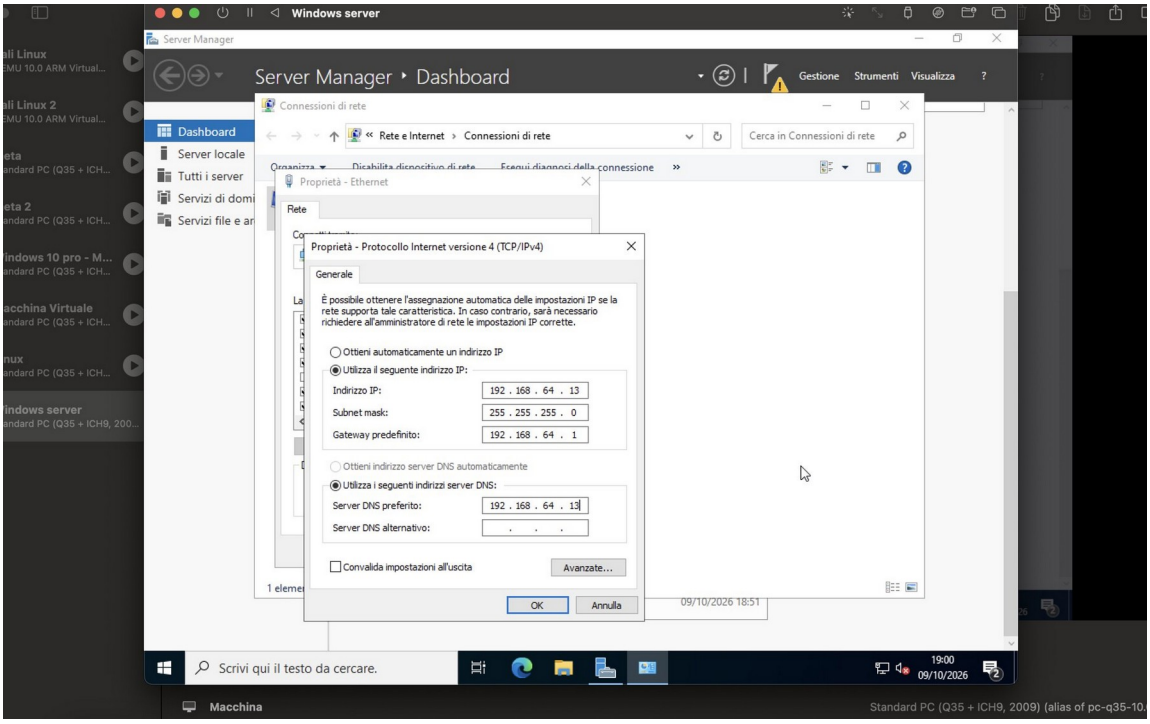


Figura 2 — Configurazione di rete in Windows Server nel contesto delle macchine virtuali UTM.

1.2 Installazione del ruolo Active Directory Domain Services

Sul sistema Windows Server è stato avviato Server Manager e selezionato il ruolo Active Directory Domain Services (AD DS), necessario a trasformare il server nel punto centrale di autenticazione e autorizzazione del dominio. La selezione delle funzionalità e la successiva procedura guidata costituiscono passaggi distinti: installare il ruolo non equivale ancora a creare il dominio.

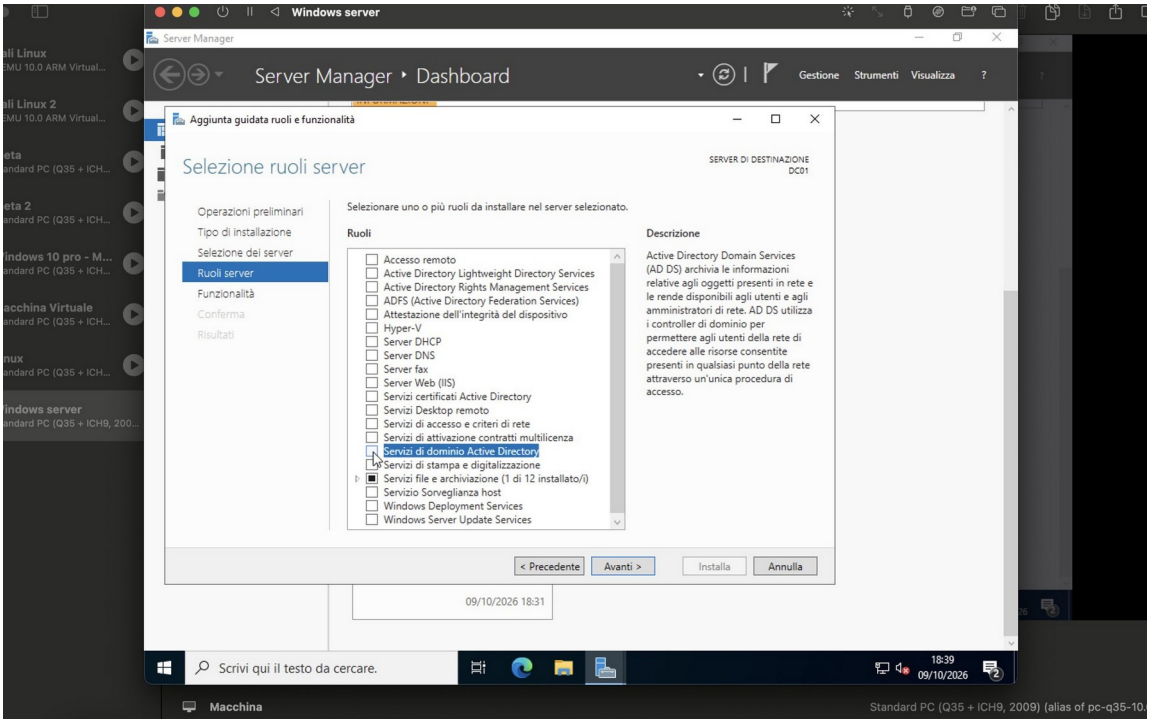


Figura 3 — Selezione di Active Directory Domain Services in Server Manager.

Terminata l'installazione dei componenti, è stata avviata la promozione del server a Domain Controller. La procedura ha permesso di creare la foresta didattica cyberlab.test e predisporre i servizi DNS richiesti per la risoluzione dei nomi e l'individuazione del controller di dominio.

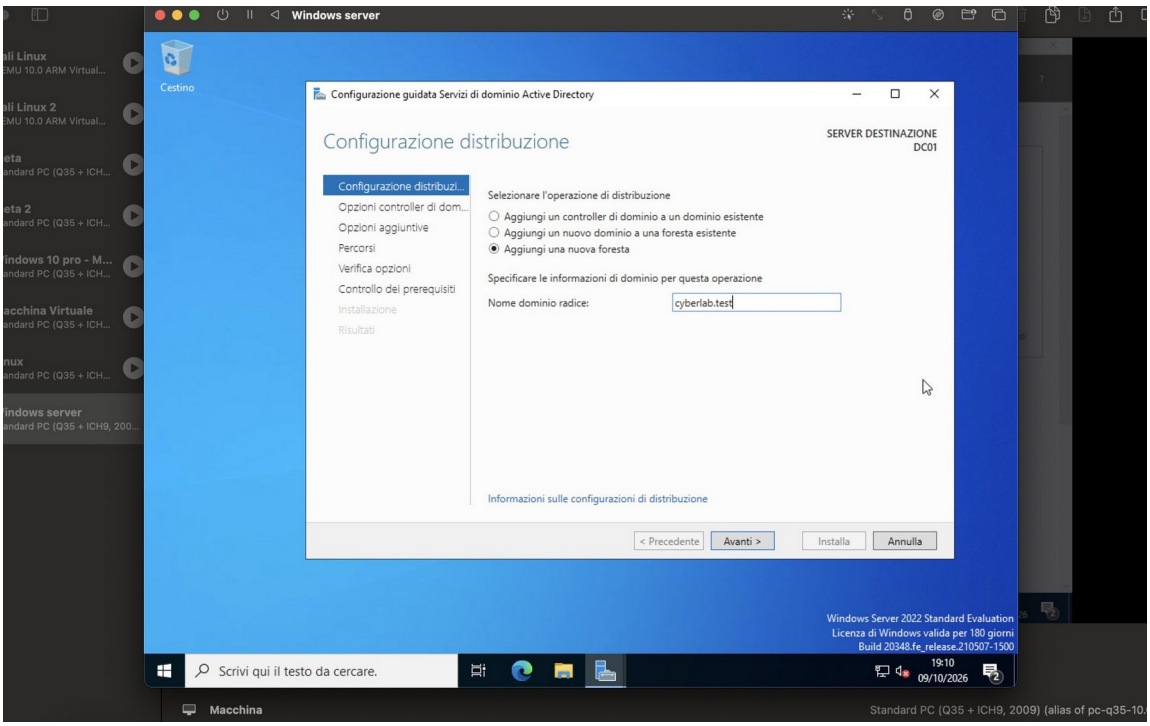


Figura 4 — Procedura di configurazione dei servizi di dominio Active Directory.

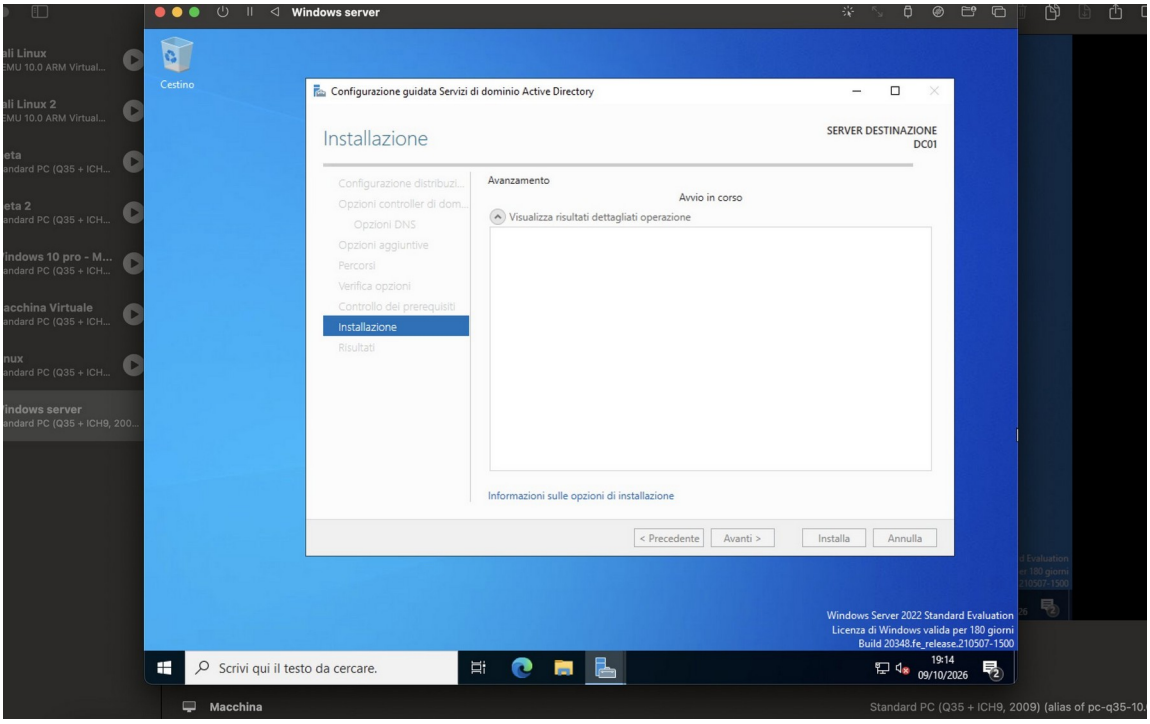


Figura 5 — Esecuzione della fase di installazione e promozione del Domain Controller.

1.3 Dominio, utenti, gruppi e organizzazione delle risorse

Dopo la promozione del server sono stati utilizzati gli strumenti di amministrazione Active Directory per gestire gli oggetti di dominio: utenti, gruppi e unità organizzative. La centralizzazione delle identità consente un unico punto di controllo per autenticazione e assegnazione dei privilegi; anche le cartelle condivise del laboratorio sono state predisposte nell'ambito delle attività di configurazione.

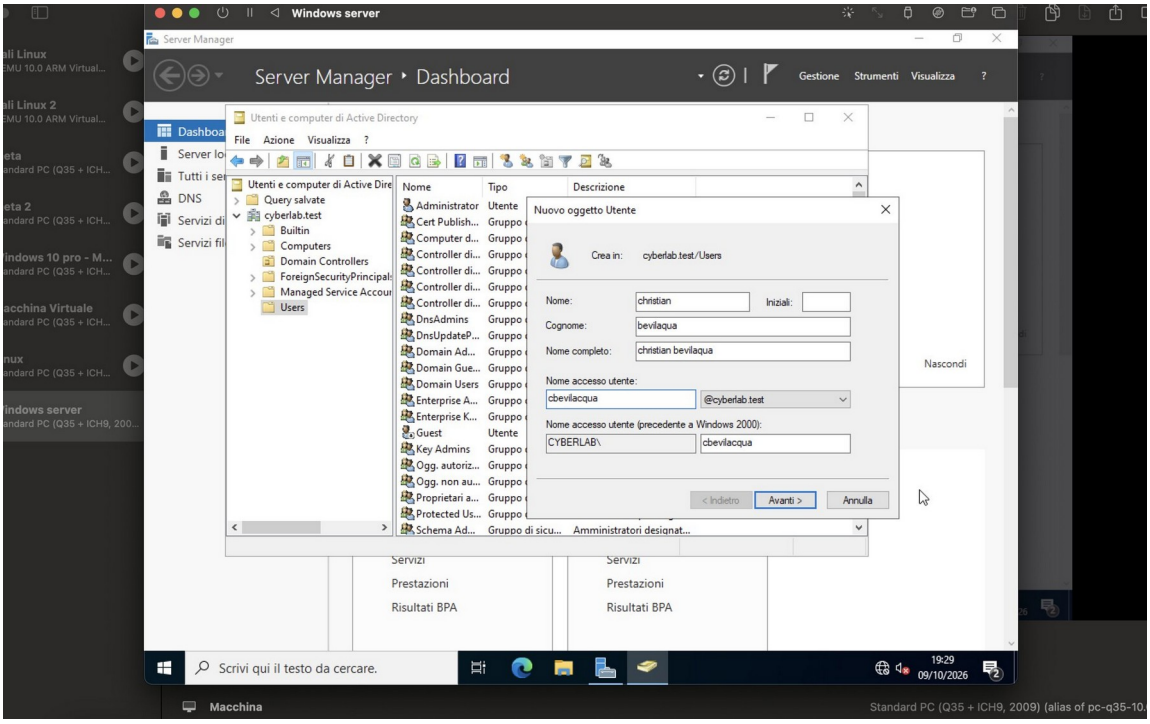


Figura 6 — Creazione e gestione degli oggetti utente tramite la console Active Directory.

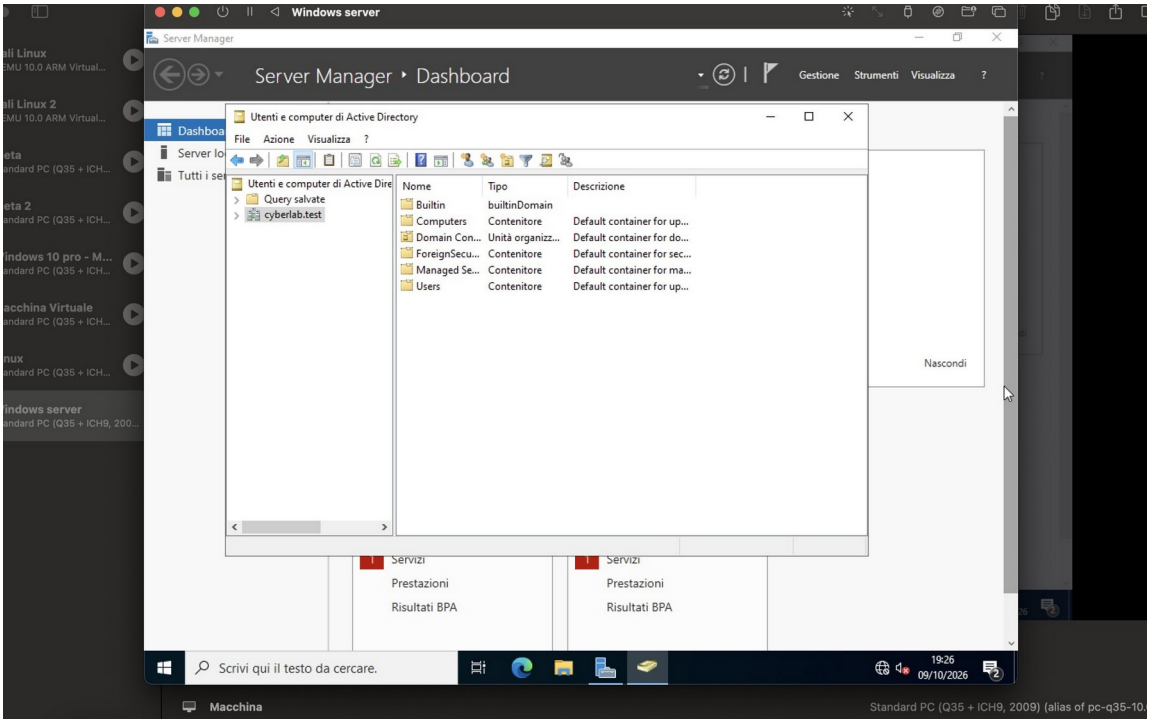


Figura 7 — Struttura del dominio e oggetti organizzativi visibili dalla console di amministrazione.

Dal punto di vista difensivo, questa componente costituisce il riferimento per analizzare l'attività degli account e riconoscere anomalie quali tentativi di autenticazione falliti, uso improprio di credenziali privilegiate o richieste anonime ai servizi di directory.

1.4 Ingresso del client Windows 10 nel dominio

Il client Windows 10 è stato predisposto come workstation di dominio. La configurazione della connettività e dei parametri DNS ha consentito al sistema di individuare il Domain Controller e completare la procedura di adesione a cyberlab.test. È stata successivamente verificata la possibilità di effettuare l'accesso con un account del dominio.

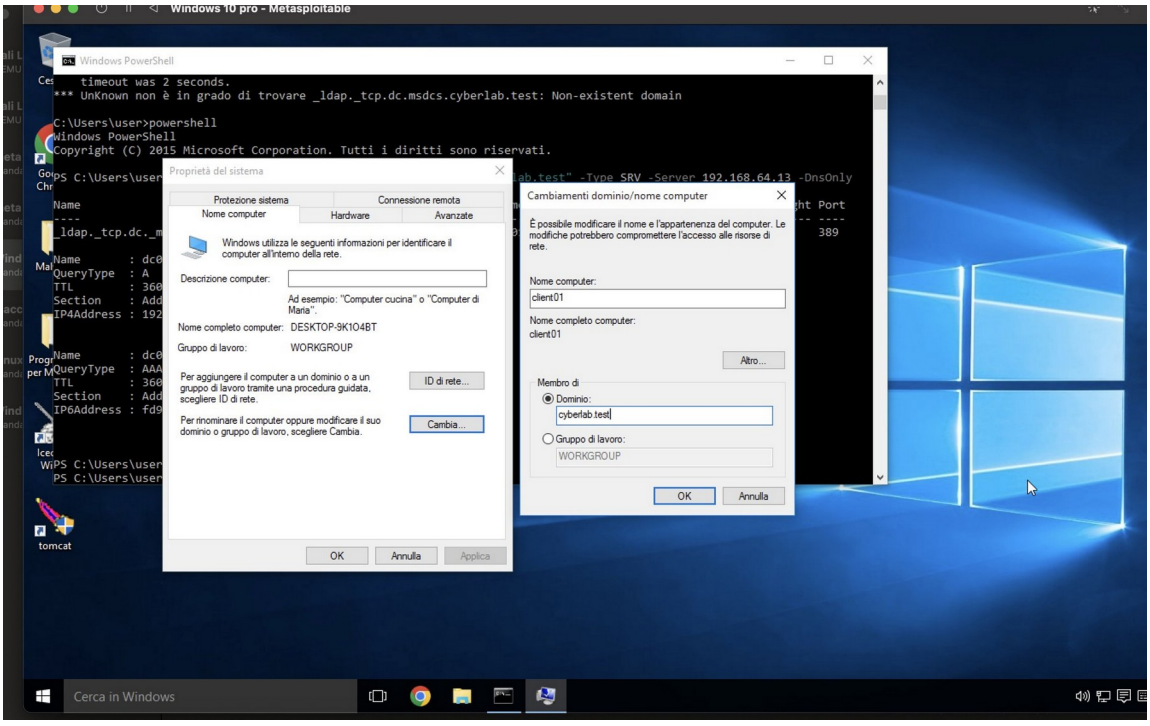


Figura 8 — Impostazione dei parametri di appartenenza al dominio sul client Windows.

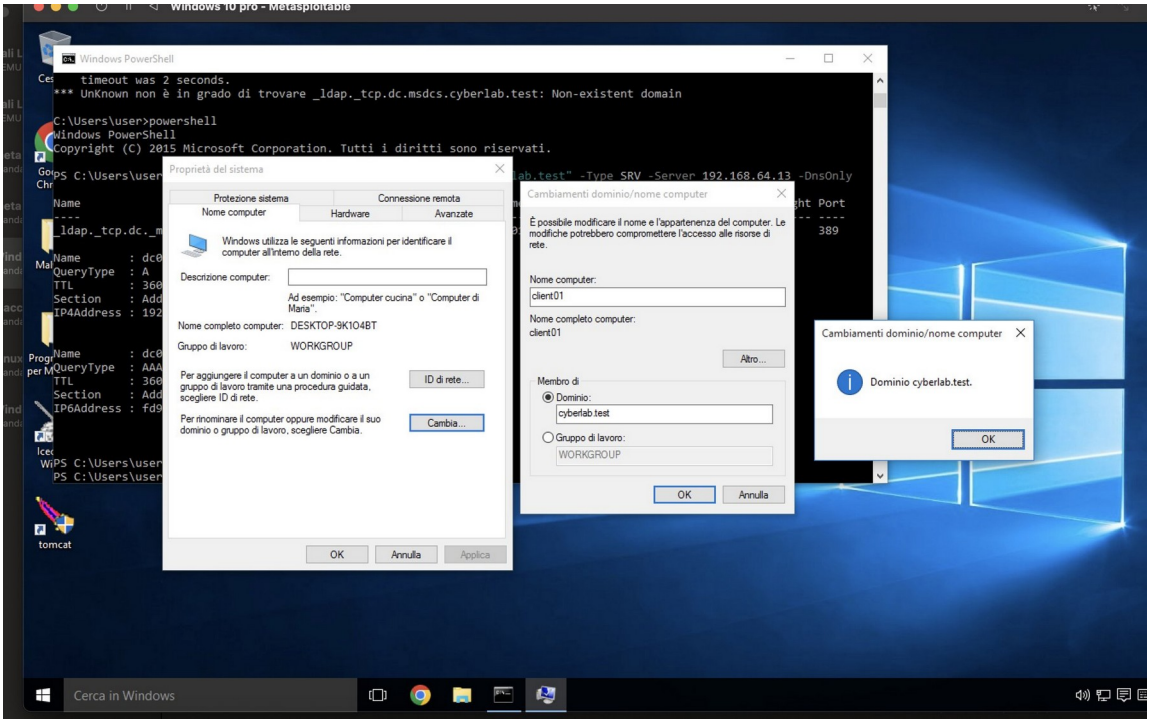


Figura 9 — Conferma della procedura di ingresso della workstation nel dominio.

La presenza di una workstation distinta dal Domain Controller è rilevante: permette di osservare eventi di accesso sulla postazione, distinguere i log generati dal server da quelli del client e progettare rilevamenti relativi al movimento laterale o all'uso anomalo degli account.

1.5 Splunk Enterprise e porta di ricezione dei Forwarder

La macchina Ubuntu è stata utilizzata come server di monitoraggio con Splunk Enterprise. Attraverso l'interfaccia amministrativa è stata preparata la ricezione dei dati inoltrati dagli Universal Forwarder. Il percorso di configurazione in Splunk comprende l'abilitazione del servizio di ascolto e l'indicazione della porta 9997/TCP, distinta dalla porta web 8000 e dalla porta di gestione Splunk 8089.

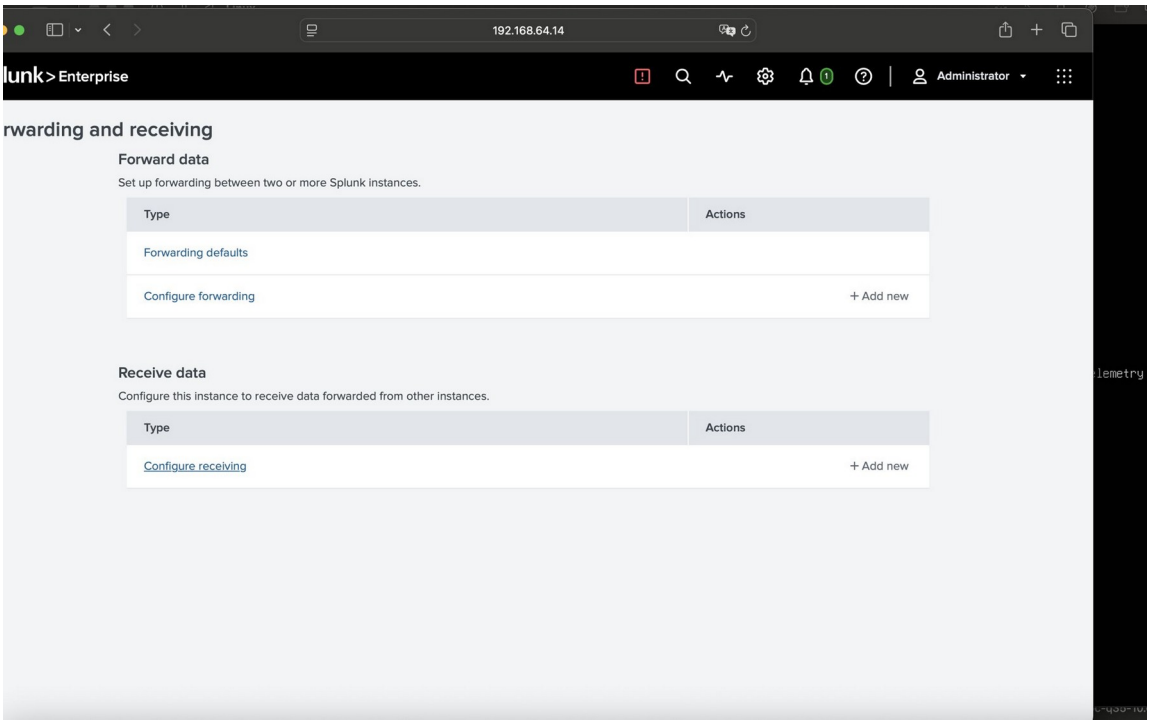


Figura 10 — Schermata Splunk di amministrazione delle funzioni di forwarding e receiving.

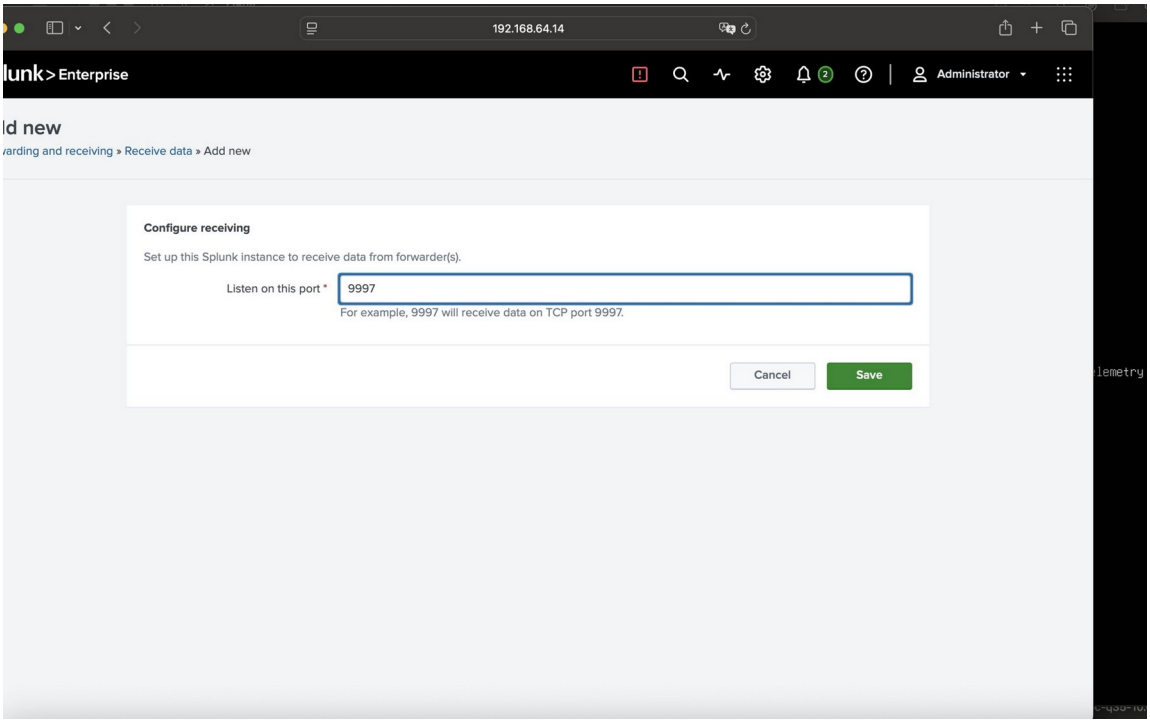


Figura 11 — Configurazione del listener di ricezione per i dati dei Forwarder, porta 9997.

1.6 Distribuzione e configurazione di Splunk Universal Forwarder

Il componente Splunk Universal Forwarder è stato installato sulle macchine Windows per rendere disponibili al SIEM i registri locali. La procedura illustrata comprende avvio del programma di installazione, selezione delle impostazioni e configurazione della destinazione Splunk. Dopo l'installazione sono state eseguite verifiche sul servizio e sull'invio dei registri, con successive correzioni di configurazione durante la messa a punto del laboratorio.

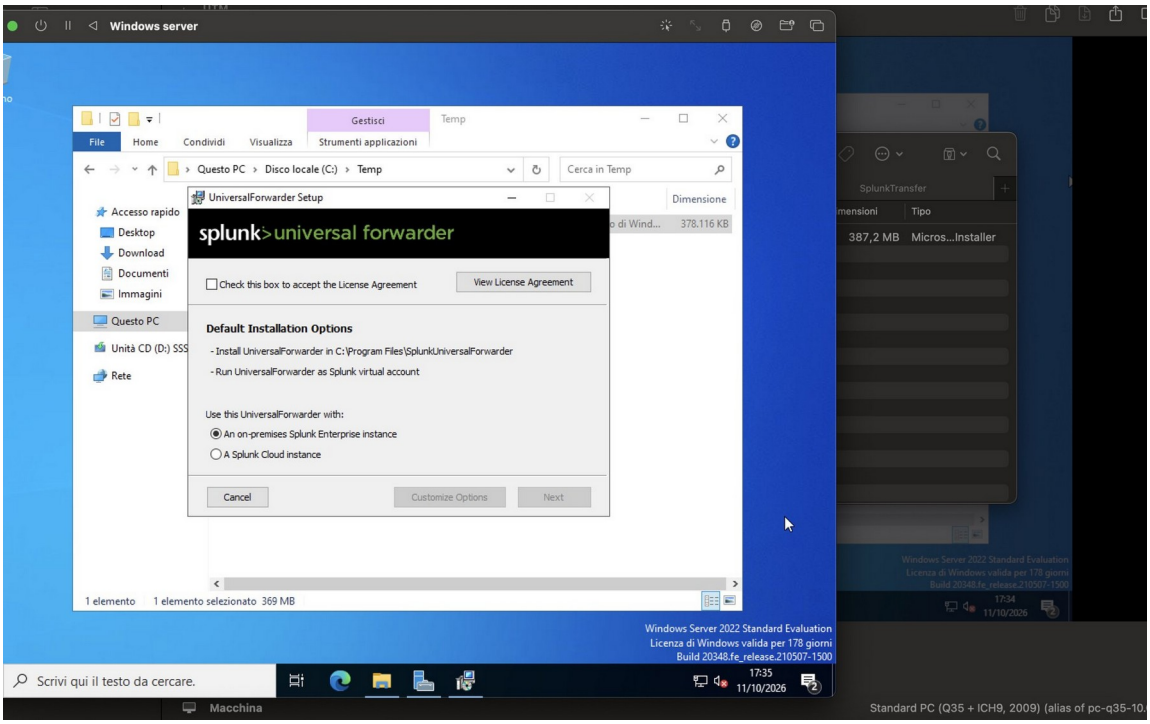


Figura 12 — Avvio e configurazione dell'installazione di Universal Forwarder sul sistema Windows.

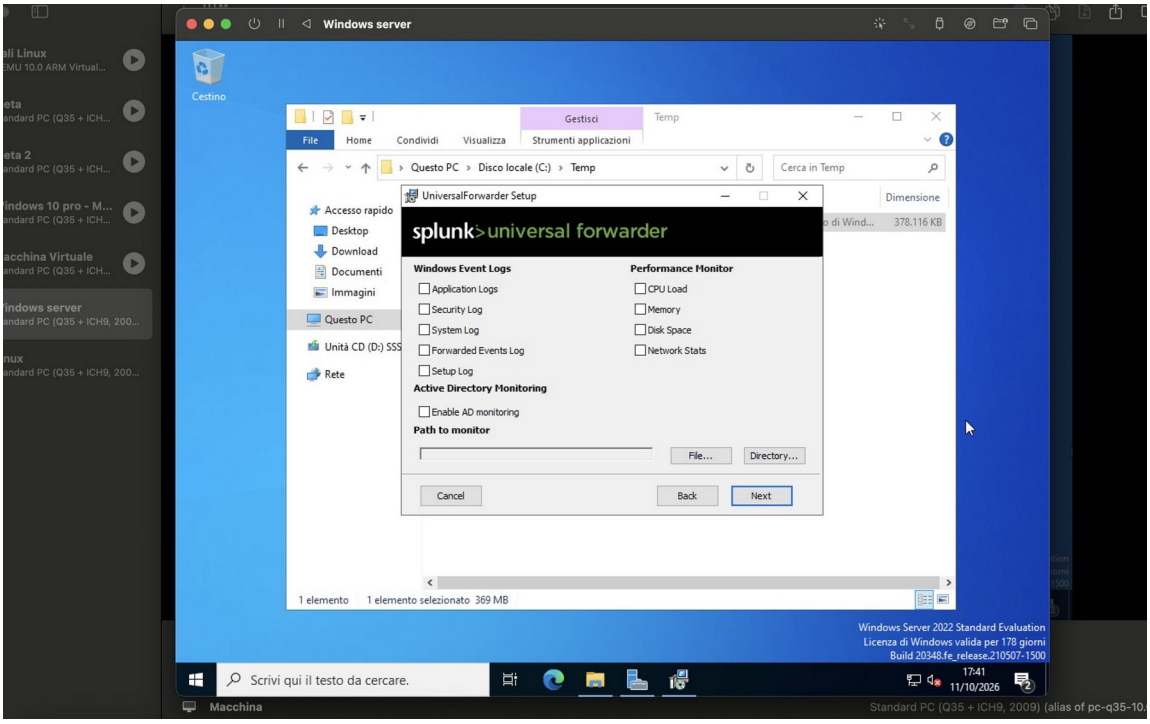


Figura 13 — Selezione degli input e delle categorie di eventi da raccogliere tramite Universal Forwarder.

Anche il client Windows 10 è stato incluso nella telemetria. Le acquisizioni relative alla workstation mostrano la procedura di installazione del Forwarder in un contesto distinto da DC01, confermando l'effettivo coinvolgimento del client nell'architettura SIEM.

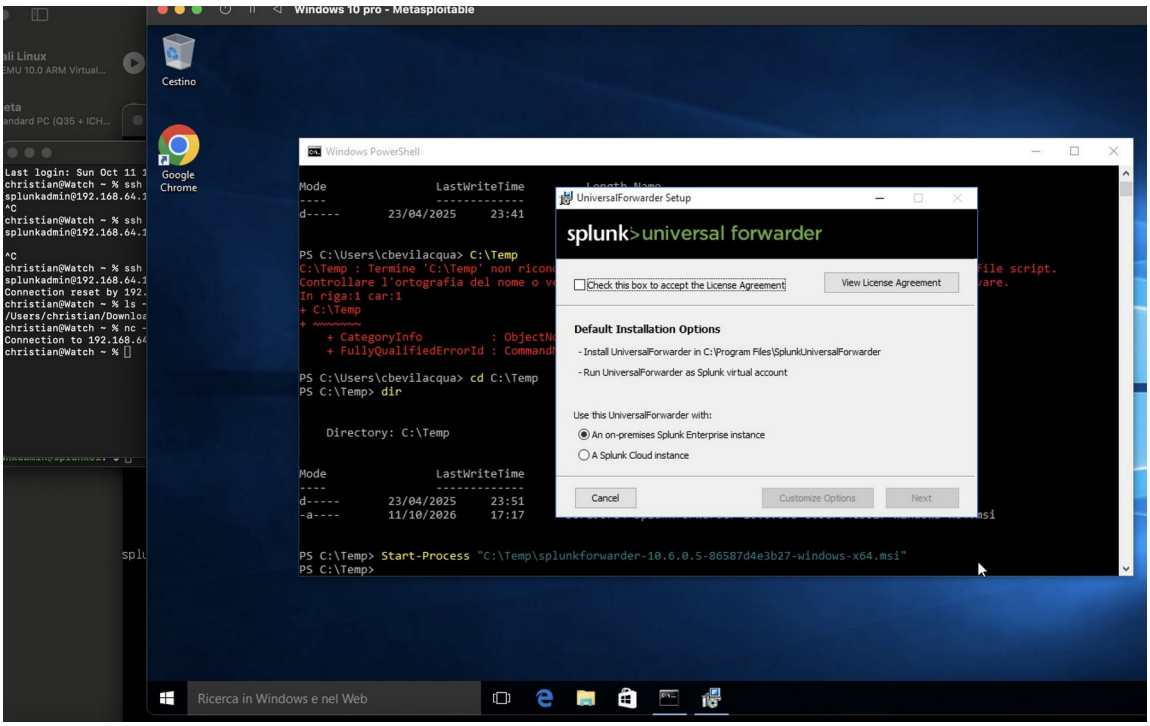


Figura 14 — Procedura di installazione di Universal Forwarder sulla macchina client Windows 10.

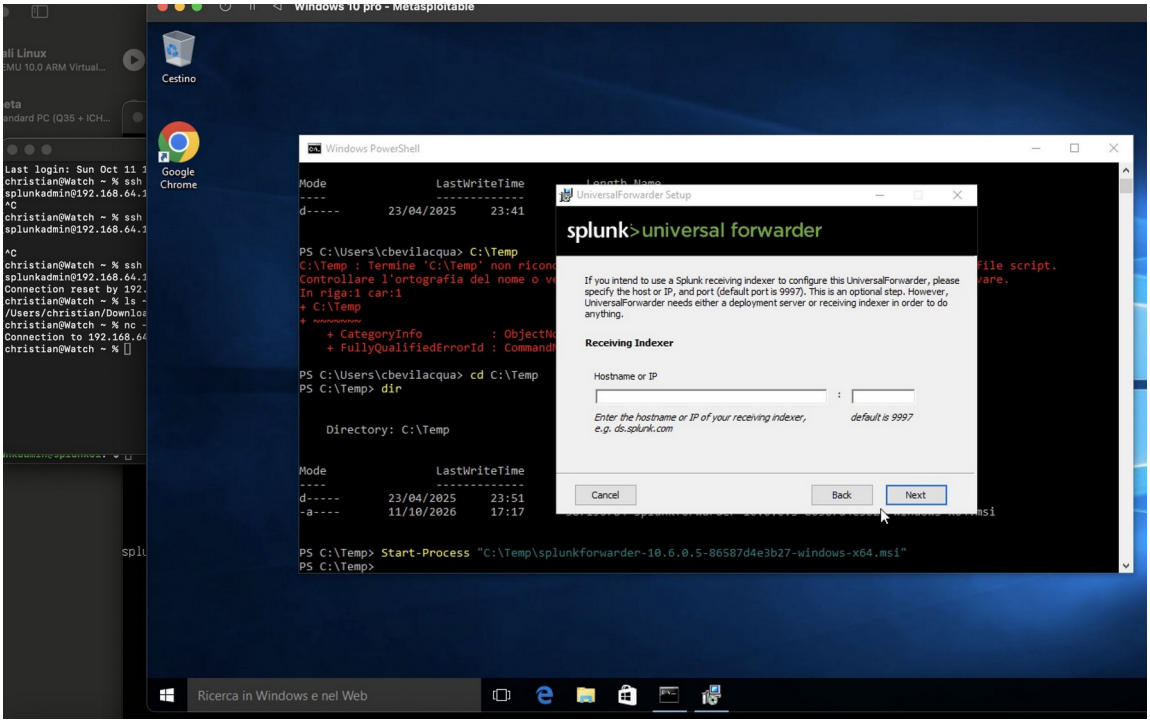


Figura 15 — Parametri di inoltro verso il server Splunk dal client Windows 10.

1.7 Controllo della disponibilità dei dati in Splunk

La validazione non si è limitata all'installazione dei pacchetti: nelle ricerche del SIEM sono stati osservati record attribuiti a DC01 e a client01. Una ricerca effettuata il 12 ottobre ha restituito 37.217 eventi Security per client01 e 3.068 per DC01 nel relativo intervallo temporale. Si tratta di conteggi riferiti al periodo selezionato, non di una misura permanente del tasso di raccolta.

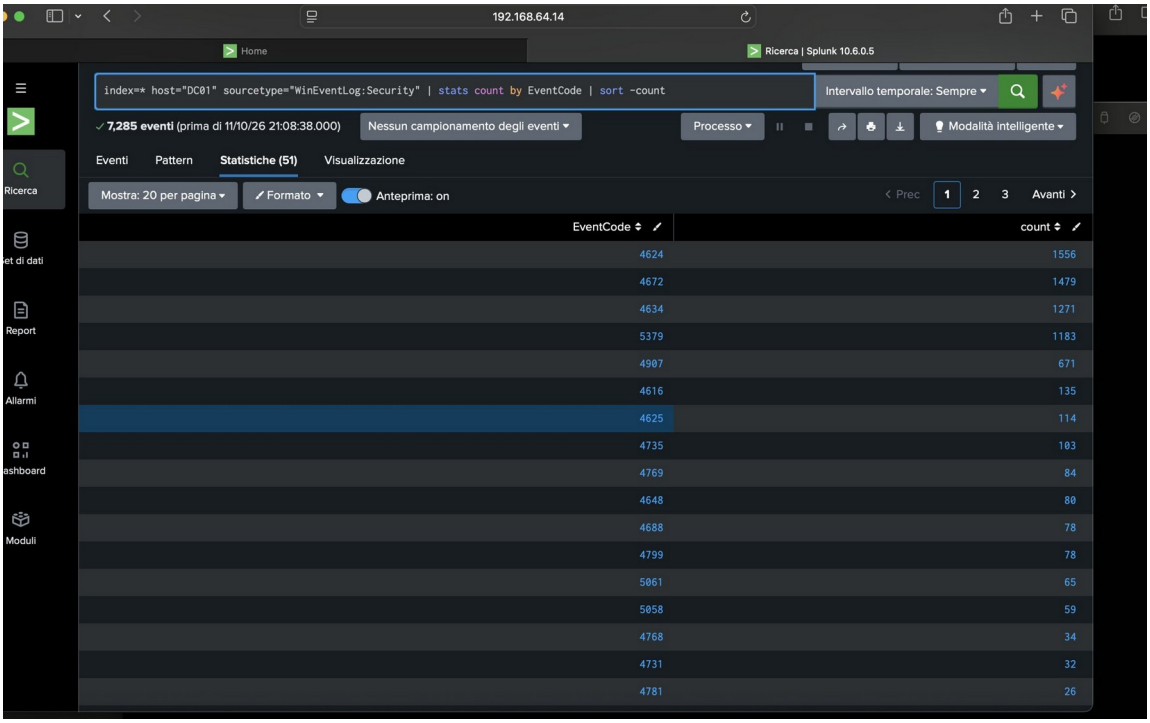


Figura 16 — Interrogazione Splunk e tabella degli eventi Windows restituiti dal SIEM.

La preparazione dell'ambiente ha quindi raggiunto l'obiettivo essenziale di collegare l'identità di dominio, una workstation e un sistema SIEM centrale. Le attività offensive descritte nelle sezioni successive sono state condotte soltanto su questo ambiente didattico autorizzato.

Domain Controller e client di dominio

Progettazione Windows e logica di autenticazione

2.1 DC01 — Windows Server

DC01 è stato configurato con Active Directory Domain Services e DNS, quindi promosso a Domain Controller del dominio cyberlab.test. Nel dominio sono stati predisposti account, gruppi e una cartella condivisa per riprodurre i servizi essenziali di una piccola rete aziendale. La risoluzione DNS del dominio è il prerequisito per individuare i controller e accedere alle risorse.

2.2 client01 — Windows 10

La workstation client01 è stata configurata sulla rete virtuale ed associata al dominio, con test di accesso mediante un account di dominio. In questa architettura l'endpoint non è soltanto un bersaglio potenziale: genera autonomamente eventi di logon, accesso alle risorse e funzionamento del sistema operativo, fondamentali per il monitoraggio centralizzato.

Livello	Funzione	Traccia utile
Identità	Account utente autenticato nel dominio	4624 / 4625, secondo host e modalità di accesso
Autorizzazione	Gruppi e permessi su risorse condivise	Eventi accesso oggetti, se auditing attivo
Endpoint	Servizi, sessioni e processi Windows	Security, System, Application
Trasporto SIEM	Universal Forwarder verso Splunk	Host, sourcetype, timestamp

2.3 Percorso degli eventi

L'evento nasce nel registro Windows; Splunk Universal Forwarder lo legge e lo invia all'indexer sulla porta TCP 9997. Sul SIEM è poi possibile filtrarlo in base a host, sourcetype, EventCode e tempo. Questa separazione è essenziale: un collegamento TCP attivo non dimostra da solo l'indicizzazione, mentre un evento ricercabile in Splunk sì.

client01 / DC01 → Windows Event Log → Universal Forwarder
→ Splunk Enterprise :9997 → Ricerca SPL

03 / LABORATORIO PRATICO

Windows 10: predisposizione della telemetria

Installazione dell'agente e monitoraggio del client

Sulla workstation Windows 10 è stato installato Splunk Universal Forwarder e sono stati impostati i flussi di acquisizione dei registri di sistema. L'installazione del software è documentata dall'immagine seguente; la prova della corretta raccolta è costituita dalle interrogazioni per host illustrate nella sezione successiva.

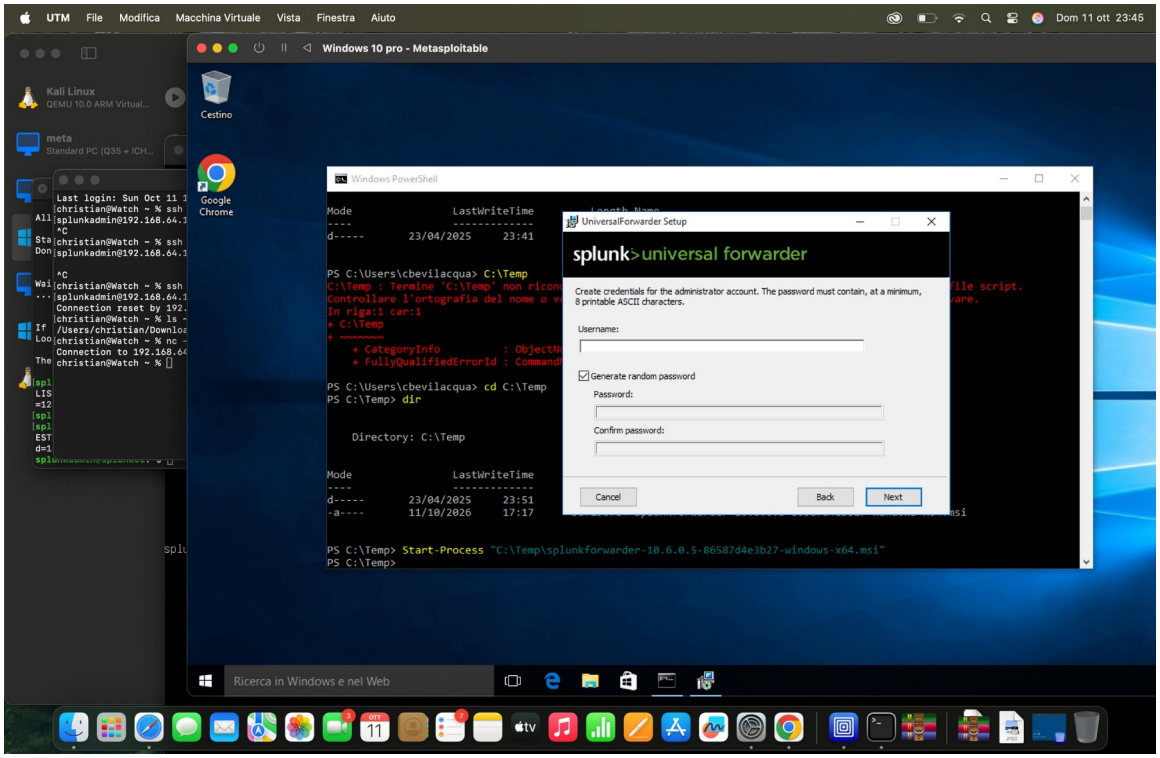


Figura 17 — Installazione di Splunk Universal Forwarder sulla workstation Windows del laboratorio.

Registri monitorati

Canale Windows	Contenuto rilevante per il laboratorio
Security	Autenticazioni, privilegi, politiche di controllo accessi
System	Stato dei servizi e condizioni operative della macchina
Application	Eventi applicativi che completano il contesto diagnostico

La separazione dei tre registri consente di passare dall'osservazione di un singolo evento di autenticazione alla diagnosi completa del sistema, soprattutto quando un Forwarder non invia dati o un servizio non si avvia correttamente.

04 / LABORATORIO PRATICO

Configurazione Splunk Universal Forwarder

Raccolta dei registri e destinazione dei dati

La configurazione dell'agente Windows usa inputs.conf per selezionare i canali da monitorare e outputs.conf per definire il server di destinazione. Il ricevitore Splunk Enterprise è esposto su 192.168.64.14:9997.

```
[WinEventLog://Security]
disabled = 0
[WinEventLog://System]
disabled = 0
[WinEventLog://Application]
disabled = 0
```

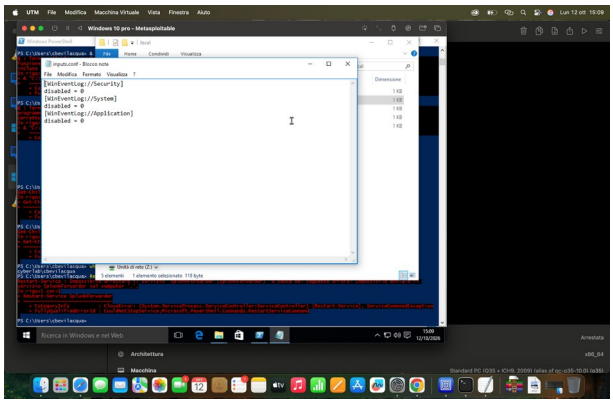


Figura 18 — Configurazione della lettura dei registri Windows.

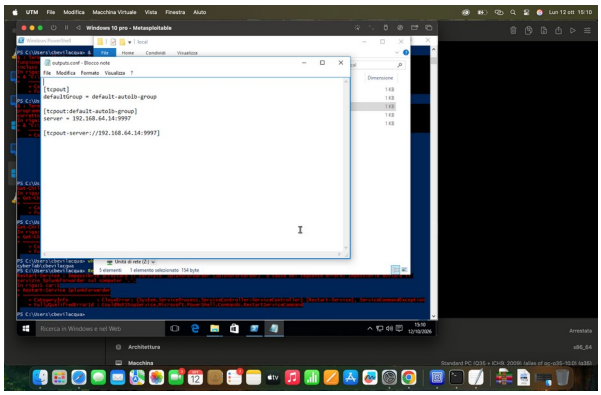


Figura 19 — Parametri di inoltro degli eventi al server Splunk.

05 / LABORATORIO PRATICO

Windows Security: prova di raccolta da due host

Validazione oggettiva del monitoraggio del client

Una ricerca Splunk eseguita il 12 ottobre alle 15:28 ha aggregato gli eventi Windows Security per host, nell'intervallo temporale selezionato. La query ha restituito due sorgenti distinte e quantificato il volume dei messaggi ricevuti.

```
index=* sourcetype="WinEventLog:Security"
| stats count by host
```

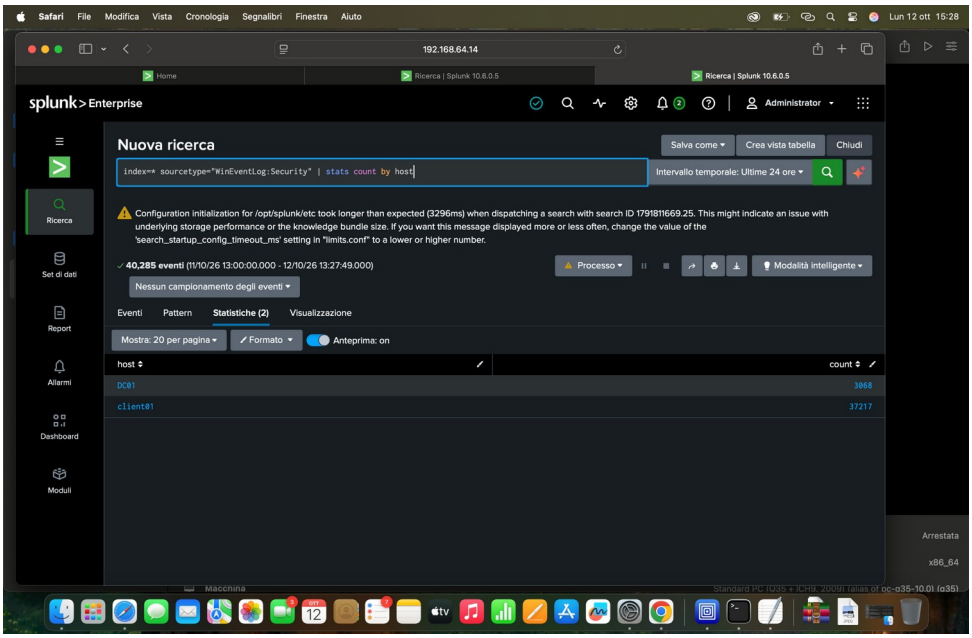


Figura 20 — Eventi indicizzati per client01 e DC01 nell'intervallo di ricerca selezionato.

Host	Eventi Security osservati	Interpretazione
client01	37.217	La workstation invia registri consultabili
DC01	3.068	Il Domain Controller è presente nella stessa pipeline
Totale	40.285	Volume aggregato dell'intervallo, non numero di attacchi

La metrica conferma l'acquisizione effettiva da client01. Non rappresenta il numero di attacchi rilevati: per dimostrare una specifica detection occorre isolare un evento attribuibile a un test, confrontando orario, account e origine di rete.

06 / LABORATORIO PRATICO

Casi d’uso difensivi sul client Windows

Analisi operativa supportata dalla telemetria disponibile

Una volta indicizzato, il registro Security dell’endpoint permette di costruire controlli riproducibili. Le ricerche seguenti sono query di analisi applicabili ai dati già raccolti: costituiscono capacità di indagine, non dichiarazioni di alert precedentemente attivati.

6.1 Sequenza temporale degli accessi

```
index=* host="client01" sourcetype="WinEventLog:Security"
(EventCode=4624 OR EventCode=4625 OR EventCode=4634)
| table _time host EventCode Message
| sort 0 -_time
```

La timeline distingue accessi riusciti, falliti e chiusure di sessione, fornendo un primo quadro di attività della workstation senza presupporre il verificarsi di un attacco.

6.2 Analisi dei tentativi non riusciti

```
index=* host="client01" sourcetype="WinEventLog:Security" EventCode=4625
| bin _time span=5m
| stats count as tentativi by _time, host
| sort 0 -tentativi
```

La finestra di cinque minuti rende confrontabili picchi di errori e accessi sporadici. Per introdurre un allarme servirebbe tarare una soglia dopo aver osservato una baseline, evitando falsi positivi.

6.3 Eventi da correlare

EventCode	Significato	Uso nell’indagine
4624	Logon riuscito	Tipo di logon, account e indirizzo origine se presente
4625	Logon non riuscito	Motivo, account, tipo di accesso e origine
4672	Privilegi speciali assegnati	Attività di amministratori e account elevati
4688	Nuovo processo creato	Visibile solo con criterio di auditing adeguato
4768 / 4771	Autenticazione Kerberos	Rilevanti soprattutto sul DC, secondo il flusso di richiesta

Per accessi remoti e processi sono pertinenti anche i canali Microsoft-Windows-WinRM/Operational e PowerShell/Operational, se opportunamente abilitati e raccolti.

07 / LABORATORIO PRATICO

Ricognizione: servizi esposti su DC01

Fase 1 — mappatura della superficie d'attacco

Da Kali Linux (192.168.64.2) è stata eseguita una scansione TCP con identificazione dei servizi del Domain Controller, senza impiego di credenziali. L'obiettivo era individuare le superfici di autenticazione e amministrazione esposte sulla rete.

```
nmap -sT -sV 192.168.64.13
```

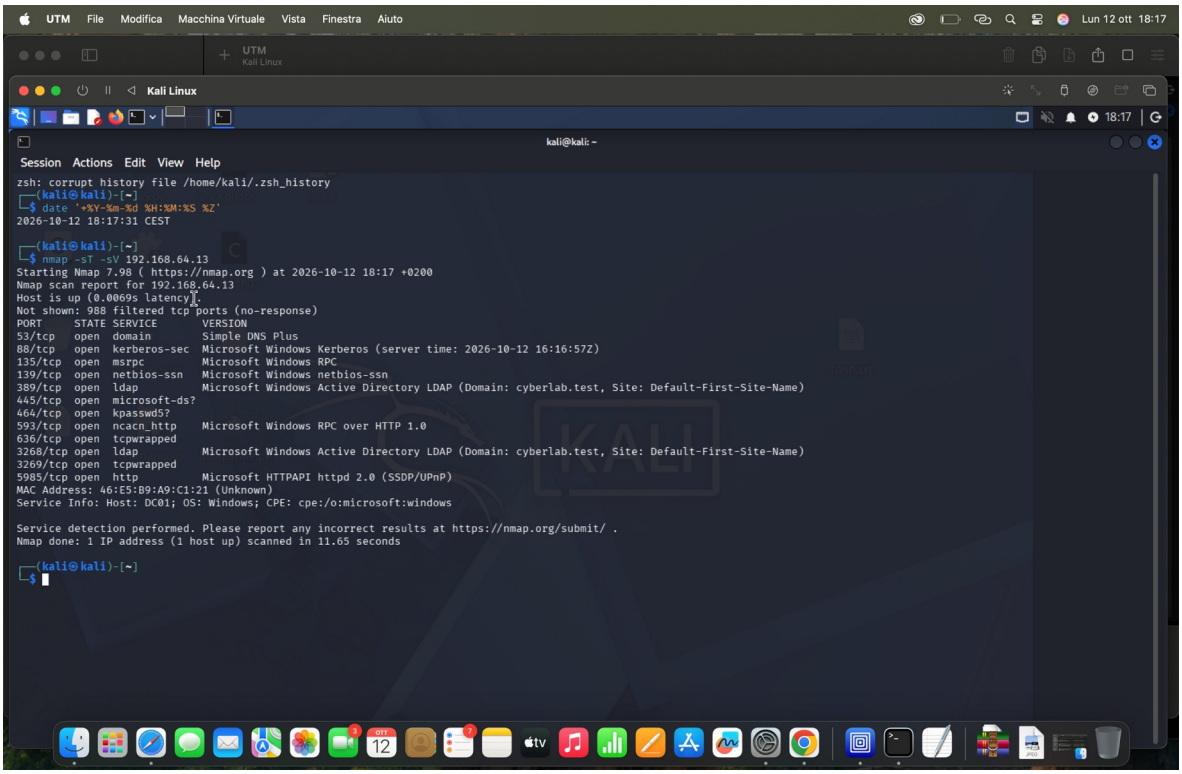


Figura 21 — Scansione Nmap eseguita il 12 ottobre alle 18:17.

Servizi individuati	Porte	Rilevanza
DNS e Kerberos	53 / 88 / 464	Infrastruttura di dominio
SMB e LDAP	445 / 389 / 636	Risorse, directory e interrogazioni
RPC e Global Catalog	135 / 593 / 3268 / 3269	Componenti tipici AD
WinRM	5985	Amministrazione e PowerShell remota

L'esposizione dei servizi è coerente con il ruolo di Domain Controller. La scansione costituisce evidenza di ricognizione, ma non viene scambiata per un alert Windows Security: una rilevazione di port scan richiederebbe telemetria di rete o una sorgente specifica.

08 / LABORATORIO PRATICO

Enumerazione LDAP, SMB e RPC

Fase 1 — accessi anonimi e risposte del controller

Sono stati effettuati quattro controlli senza credenziali per misurare il livello di informazioni ottenibili da un host non autenticato. I risultati forniscono indicazioni utili sulle protezioni predefinite della directory.

```
ldapsearch -x -H ldap://192.168.64.13 -b "DC=cyberlab,DC=test" -s base
smbclient -L //192.168.64.13 -N
rpcclient -U "" -N 192.168.64.13 -c "enumdomusers"
rpcclient -U "" -N 192.168.64.13 -c "getdompwinfo"
```



Figura 22 — Esiti delle richieste anonime ai servizi di directory e condivisione.

Tecnica	Risposta	Conclusione
LDAP anonimo	Bind autenticato richiesto	Informazioni non enumerate
SMB anonimo	Login anonimo accettato, nessuna share elencata	Nessuna condivisione ricavata
RPC enumdomusers / getdompwinfo	NT_STATUS_ACCESS_DENIED	Enumerazione e criteri password non accessibili

09 / LABORATORIO PRATICO

Autenticazione NTLM: detection confermata

Fase 2 — test controllato delle credenziali

È stato eseguito da Kali un singolo tentativo SMB con l'utente di prova test_epicode, non riconosciuto nel dominio. La risposta lato Kali è stata NT_STATUS_LOGON_FAILURE. Sul SIEM è stato identificato il corrispondente evento Windows Security 4625, con indirizzo sorgente di Kali.

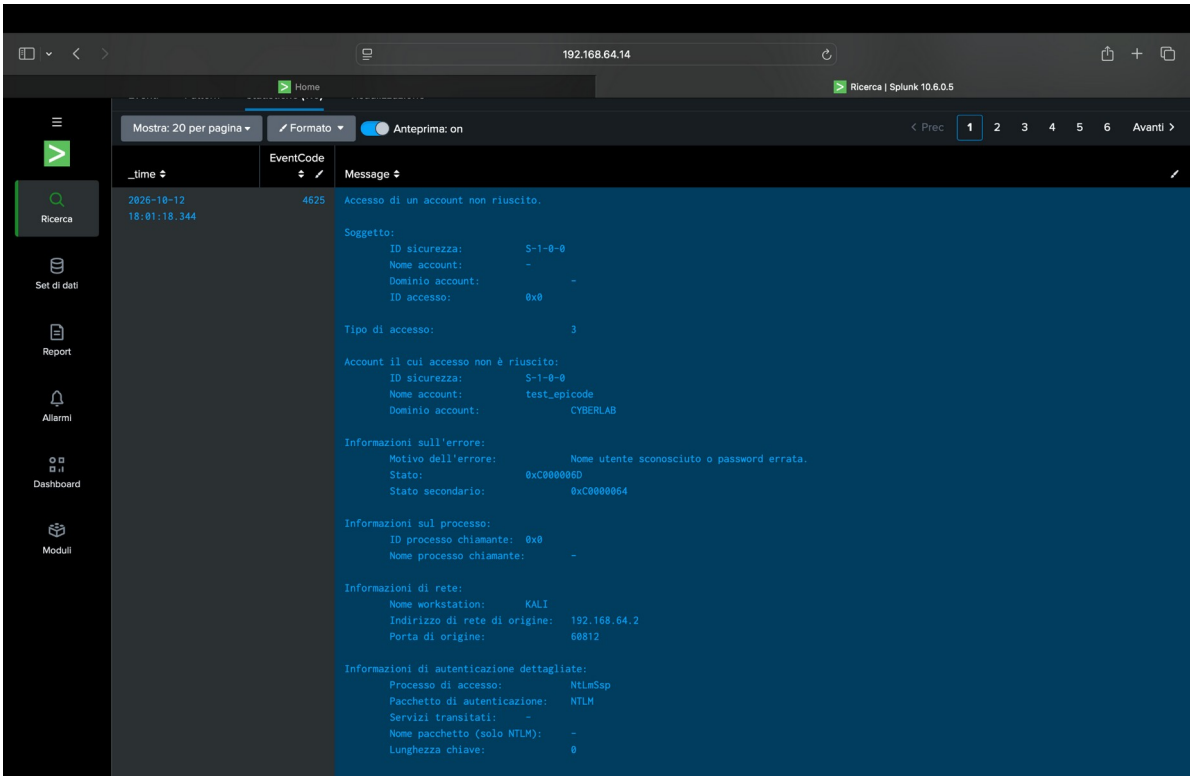


Figura 23 — Security Event 4625 acquisito da Splunk: test_epicode e origine 192.168.64.2.

Campo dell'evento	Valore osservato
EventCode / Tipo di accesso	4625 / 3 (accesso di rete)
Utente e dominio	test_epicode / CYBERLAB
Sorgente	192.168.64.2 — KALI
Stato / substatus	0xC000006D / 0xC0000064
Protocollo	NTLM

Questa è la prova più solida di detection end-to-end: attività generata sulla macchina di test, evento prodotto sul controller e relativa registrazione consultabile in Splunk. Il substatus 0xC0000064 indica un nome utente inesistente; non si conclude quindi che sia stata indovinata o compromessa una password.

10 / LABORATORIO PRATICO

Kerberos: verifica della preautenticazione

Fase 2 — scenario AS-REP Roasting

L'interrogazione Kerberos con Impacket ha verificato se l'account Administrator fosse configurato per ottenere una risposta AS-REP senza preautenticazione. Il Domain Controller ha negato la condizione necessaria allo scenario.

```
impacket-GetNPUsers cyberlab.test/Administrator -no-pass -dc-ip 192.168.64.13
```

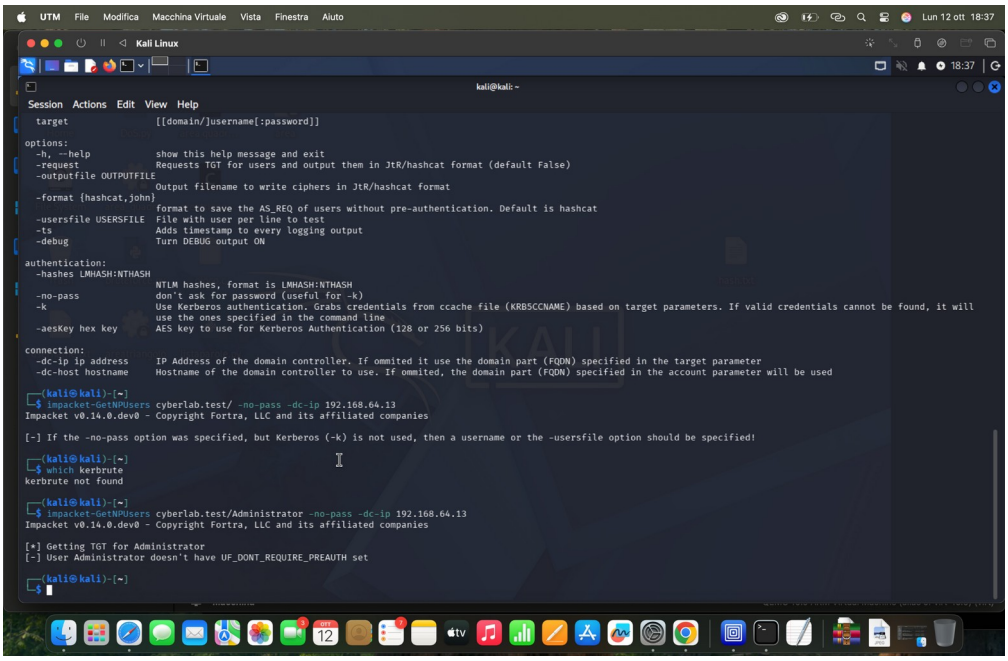


Figura 24 — Esito GetNPUsers: preautenticazione Kerberos richiesta per Administrator.

Il messaggio "User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set" indica che, in questa prova, non è stato ottenuto materiale utilizzabile per un attacco AS-REP Roasting. Questo rappresenta un controllo di sicurezza osservato, non un errore tecnico del test.

Verifica di correlazione

```
index=* host="DC01" sourcetype="WinEventLog:Security"
(EventCode=4768 OR EventCode=4771) "192.168.64.2"
| table _time EventCode Message
```

La ricerca non ha identificato eventi di tali categorie attribuibili con certezza all'indirizzo di Kali. L'esito resta quindi documentato lato protocollo e comando, senza rivendicare una detection Kerberos non provata.

11 / LABORATORIO PRATICO

WinRM e comando remoto autorizzato

Fase 3 — simulazione post-compromissione

La porta 5985 identificata in ricognizione è stata sottoposta a una prima richiesta HTTP senza credenziali: il servizio ha risposto 401 e ha richiesto l'autenticazione tramite Negotiate/Kerberos. Successivamente, mediante credenziali amministrative note nel laboratorio, è stata aperta una sessione PowerShell remota da Kali.

```
curl -i -X POST -d "test" --max-time 10 http://192.168.64.13:5985/wsman
evil-winrm -i 192.168.64.13 -u Administrator
whoami
```



Figura 25 — Sessione Evil-WinRM autorizzata e output cyberlab\administrator.

Verifica	Risultato
Richiesta WinRM anonima	HTTP 401; autenticazione necessaria
Sessione con credenziali del laboratorio	PowerShell remota aperta su DC01
Comando innocuo	whoami → cyberlab\administrator

La prova dimostra l'esecuzione remota su DC01 con credenziali autorizzate. È una simulazione di accesso post-compromissione, non un furto reale di credenziali né una catena completa di movimento laterale fra due endpoint.

12 / LABORATORIO PRATICO

Correlazione SIEM e attribuzione degli eventi

Dalla telemetria grezza alla prova di rilevamento

Dopo la sessione remota è stato cercato un evento Security riconducibile a Evil-WinRM. In Splunk è presente un evento 4624 dell'account CYBERLAB\Administrator alle 18:49:44, con logon di tipo 3; tuttavia la schermata non contiene l'IP di origine e non permette di attribuire con certezza quell'accesso al comando eseguito da Kali intorno alle 18:51.

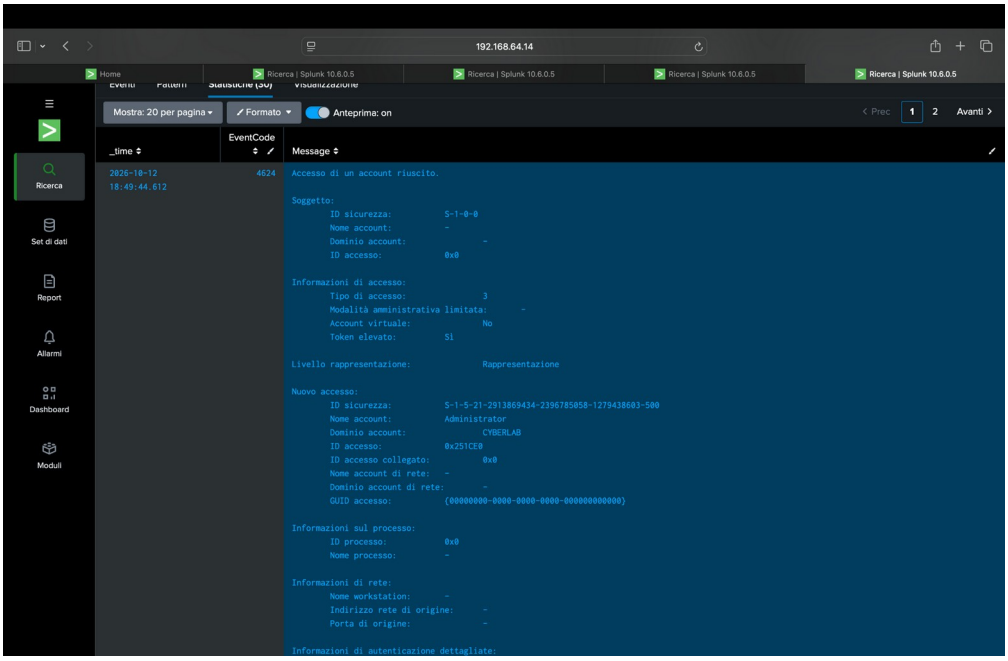


Figura 26 — Evento 4624 di Administrator: il dato disponibile non è sufficiente per attribuire la sessione a Kali.

Criterio di attribuzione applicato

Requisito	Disponibilità
Esecuzione remota osservata dal terminale Kali	Sì: sessione attiva e whoami
Identità amministrativa visibile su un evento 4624	Sì: accesso osservato prima della prova
Stesso IP sorgente della macchina di test	Non presente nell'evento mostrato
Corrispondenza certa di orario, accesso e processo	Non dimostrata

La distinzione fra accesso riuscito e rilevamento attribuito è metodologicamente importante: la ricerca di soli eventi 4624 non basta. Per migliorare la correlazione occorrono auditing della creazione processi, log WinRM/PowerShell e un riferimento temporale coerente fra le macchine.

13 / LABORATORIO PRATICO

Detection engineering e miglioramenti

Query riproducibili, limiti della raccolta e priorità operative

13.1 Regola di analisi — accessi falliti da una stessa origine

```
index=* sourcetype="WinEventLog:Security" EventCode=4625
| bin _time span=5m
| stats count as fallimenti by _time host Source_Network_Address
| sort 0 -fallimenti
```

Applicazione: monitorare incrementi anomali di errori di autenticazione. La soglia di allarme va definita solo dopo aver verificato che il campo origine sia valorizzato e normalizzato.

13.2 Regola di analisi — accessi amministrativi

```
index=* host="DC01" sourcetype="WinEventLog:Security"
(EventCode=4624 OR EventCode=4672)
| table _time host EventCode Account_Name Logon_Type Message
| sort 0 -_time
```

Applicazione: ricostruire il contesto degli accessi elevati. Si tratta di una query di triage, non di una prova che ogni sessione elevata provenga da un aggressore.

13.3 Copertura da estendere

Priorità	Intervento difensivo	Beneficio
Alta	Abilitare e collezionare l'audit process creation (4688)	Tracce di avvio processi e PowerShell
Alta	Acquisire WinRM/Operational e PowerShell/Operational	Contesto aggiuntivo per sessioni remote
Alta	Limitare WinRM e privilegi amministrativi	Riduzione del rischio con credenziali valide
Media	Uniformare orari / fuso e controllare ingest delay	Correlazione temporale affidabile
Media	Baseline e soglie sugli eventi 4625	Rilevazione più specifica, meno falsi positivi

Le regole SPL presenti in questa sezione sono proposte tecniche verificabili, non alert già attivati o risultati di attacchi aggiuntivi.

14 / LABORATORIO PRATICO

Perimetro di completamento, vincoli infrastrutturali ed estensioni progettate

L'attività ha permesso di realizzare il laboratorio, produrre dati telemetrici da due sistemi Windows ed eseguire più verifiche offensive e difensive. Non tutte le correlazioni o le simulazioni ipotizzate nella pianificazione iniziale sono state completate con la medesima profondità di evidenza. La distinzione tra attività dimostrate e procedure di estensione è parte integrante della valutazione tecnica del progetto.

Vincoli di esecuzione e gestione delle risorse

Il laboratorio è stato sviluppato su un portatile Apple Silicon con 8 GB di RAM complessivi, risorsa condivisa tra il sistema host e le quattro macchine virtuali. Durante le sessioni sono stati osservati rallentamenti, interruzioni delle attività interattive e tempi di avvio elevati di alcuni servizi, incluso Splunk. Il carico simultaneo di un Domain Controller Windows, una workstation Windows, un server Ubuntu/SIEM e una macchina Kali ha limitato la possibilità di mantenere tutte le componenti attive in modo continuativo. L'entità specifica del consumo di memoria non è stata misurata in un benchmark dedicato: il vincolo è riportato in base ai rallentamenti e alle difficoltà operative effettivamente riscontrati.

Per preservare l'integrità dell'ambiente sono state privilegiate sessioni di lavoro brevi, accensione selettiva delle macchine, controllo della connettività e validazione progressiva dei log. Questo approccio ha consentito di completare il nucleo del progetto, pur riducendo il tempo disponibile per ampliare le simulazioni e consolidare tutti i casi d'uso di detection.

Verifiche aggiuntive sul client Windows 10 — metodologia prevista

La fase successiva, non documentata da una sequenza completa di test offensivi sul client, avrebbe riguardato l'osservazione controllata delle autenticazioni locali e di dominio. A tale scopo, il client avrebbe dovuto rimanere avviato insieme al Domain Controller e al SIEM, con Forwarder attivo e auditing dei registri Security verificato. L'esperimento avrebbe previsto alcuni tentativi di accesso con credenziali di prova, controllando gli Event ID 4625 (accesso fallito) e 4624 (accesso riuscito), il tipo di logon e la macchina di origine. Una prova RDP sarebbe stata possibile soltanto dopo aver verificato che l'edizione di Windows e la configurazione della workstation supportassero effettivamente il servizio.

Query SPL proposta per individuare gli accessi al client:

```
index=* host="client01" sourcetype="WinEventLog:Security" (EventCode=4624 OR EventCode=4625)
| table _time host EventCode Account_Name Logon_Type Message
| sort 0 -_time
```

Questa ricerca rappresenta una procedura di validazione riproducibile: non viene presentata come prova dell'avvenuta esecuzione di nuovi tentativi contro il client.

Approfondimento Kerberos — test in un account dedicato

Il controllo effettivamente eseguito con GetNPUsers su Administrator ha mostrato la richiesta della preautenticazione Kerberos; non è stato ottenuto alcun hash AS-REP. Per completare il caso d'uso, in una successiva sessione isolata si potrebbe creare un account temporaneo con un'impostazione deliberatamente debole, ripetere il controllo e confrontare gli eventi generati con quelli del caso protetto. L'account di test dovrebbe essere rimosso o riportato a una configurazione sicura al termine della prova. In questa consegna viene valutata solo la verifica difensiva realmente osservata.

Process creation e sessioni WinRM — telemetria da estendere

L'esecuzione remota di whoami attraverso Evil-WinRM è stata osservata direttamente su Kali. Non è stata tuttavia dimostrata la presenza in Splunk di un evento attribuibile senza ambiguità alla medesima sessione. L'indagine successiva avrebbe richiesto la verifica dell'audit di creazione processi (Event ID 4688), dei log Microsoft-Windows-WinRM/Operational, dei dettagli di accesso dell'account Administrator e degli orari effettivi di ricezione. La sola presenza di un generico evento 4624, in assenza di un indirizzo sorgente e di una correlazione temporale attendibile, non è sufficiente a dimostrare quella detection.

Esempio di ricerca per un eventuale audit di process creation:

```
index=* host="DC01" (EventCode=4688 OR source="WinEventLog:Microsoft-Windows-WinRM/Operational")
| table _time host source EventCode Message
| sort 0 -_time
```

La ricerca è riportata come strumento operativo futuro. Per ottenere risultati è necessario che il relativo canale sia abilitato sul sistema Windows e incluso nella configurazione di raccolta del Forwarder.

Stato finale delle attività e prospettive di completamento

Il risultato raggiunto comprende: infrastruttura di dominio funzionante, workstation Windows inserita nel dominio, SIEM con eventi Windows acquisiti, ricognizione dei servizi, verifica dei controlli sulle enumerazioni anonime, autenticazione NTLM fallita correttamente riconosciuta nei Security log e apertura di una sessione remota autorizzata con credenziali di laboratorio. Restano da approfondire l'analisi sistematica degli eventi generati sul client, il test Kerberos con account dedicato e la detection certa della sessione WinRM. Tali punti sono documentati con una metodologia di completamento tecnica anziché con schermate non autentiche.

Nel complesso, il progetto dimostra la realizzazione di un ambiente di dominio monitorato, la conoscenza delle principali sorgenti Windows Security e un processo di verifica in cui ogni conclusione è vincolata alle evidenze effettivamente acquisite. Le limitazioni hardware hanno imposto di concentrare gli sforzi sulla continuità della raccolta e su un numero selezionato di esperimenti, lasciando tracciati i passaggi necessari per ampliare il lavoro.

Valutazione finale

Esiti, solidità delle prove e indicazioni operative

Risultati raggiunti

Il laboratorio ha prodotto un dominio Active Directory con client Windows, una pipeline Splunk funzionante da due host e una sequenza documentata di prove di ricognizione, autenticazione e comando remoto. La disponibilità dei registri Security di client01 è stata misurata direttamente in Splunk; l'evento 4625 ha permesso una correlazione concreta fra Kali e il SIEM.

Analisi delle condizioni di sicurezza

Il Domain Controller espone i servizi necessari al dominio ma limita l'enumerazione LDAP e RPC anonima. L'account Administrator mantiene la preautenticazione Kerberos. Il test WinRM dimostra invece perché l'esposizione del servizio e l'uso di credenziali privilegiate richiedano restrizioni di rete, minimo privilegio e maggiore visibilità dei processi.

Limiti della correlazione

Le evidenze disponibili non consentono di attribuire un record Windows Security specifico alla sessione Evil-WinRM. Inoltre non è stato documentato un attacco direttamente contro client01: la sua presenza nel SIEM è dimostrata dai log indicizzati, mentre le query proposte per la workstation costituiscono strumenti di analisi e scenari di validazione, non rilevamenti offensivi già osservati.

Conclusione

L’esperienza evidenzia il valore della combinazione fra amministrazione di un dominio Windows, test controllati e capacità di osservazione SIEM. Il risultato più significativo non è soltanto l’esecuzione dei comandi: è la distinzione rigorosa fra eventi realmente raccolti, controlli che hanno impedito un’azione e attività riuscite la cui telemetria necessita di un ulteriore approfondimento. Questa distinzione rende la valutazione del laboratorio riproducibile e tecnicamente attendibile.

Riferimenti tecnici

• Microsoft Learn — Audit logon, Event ID 4624 e 4625

• Microsoft Learn — Event ID 4688, Audit Process Creation

• Microsoft Learn — Windows Remote Management / PowerShell Remoting

• Splunk Documentation — inputs.conf, outputs.conf e ricerche SPL

Prove raccolte nel laboratorio nei giorni 11–12 ottobre 2026. Tutti gli screenshot riportati nel report provengono dalle sessioni e dalle VM documentate.